PHP2Shell 2026 | Case Study 002

PUBLIC RESEARCH EDITION | 23 OCTOBER 2026

SYNTHETIC RULE-BASED DEMONSTRATION — NOT A LIVE SECURITY TEST

Executive summary

PHP2Shell comprises CVE-2026-109618 and CVE-2026-109619, two PHP runtime memory-safety issues publicly disclosed on 21 October 2026. This case study combines verified public incident evidence with an explicitly synthetic, reproducible triage benchmark. It does NOT demonstrate that OpenVals or RedShield detected, exploited, prevented or remediated PHP2Shell.

Research question

How can enterprises independently validate the reliability, accuracy, security and operational effectiveness of AI systems used for vulnerability discovery, threat detection and remediation? Answer: use independent ground truth, deployment-aware test sets, blinded adjudication, deterministic checks for machine-verifiable claims, calibration, regression testing, and human approval for risky actions.

Verified incident facts

The PHP project confirmed the two CVEs and released PHP 8.2.35, 8.3.36, 8.4.27 and 8.5.12 on 21 October 2026. It described out-of-memory corruption and stale global state. Wiz reported proof-of-concept exploitation on selected WordPress, Drupal and Joomla environments and described AI-assisted vulnerability research. Those are third-party research demonstrations, not tests performed by this project.

What we actually executed

A deterministic Python standard-library script generated 240 SYNTHETIC asset-inventory cases with PHP branch, patch level, claimed vendor backport, verification status and exposure. Two offline rule-based classifiers were evaluated: a version-only heuristic and a version-plus-verified-backport rule. No LLM, OpenVals runtime, RedShield, live PHP server, exploit, WAF, cloud logs, or enterprise data was used.

Measured synthetic benchmark results

Version-only baseline: accuracy 97.08%; action precision 95.98%; action recall 100.00%; false-positive rate 9.59% (TP=167, FP=7, FN=0, TN=66). Verified-backport rule: accuracy 100.00% (TP=167, FP=0, FN=0, TN=73). The 100% score is expected and NOT evidence of model capability: ground truth was constructed using the same logic as the rule.

Interpretation

In this toy benchmark, ignoring vendor backports produces 7 unnecessary remediation alerts out of 73 truly patched cases. Requiring verifiable patch evidence avoids those errors by construction. This illustrates why vulnerability triage must distinguish version strings, backported security fixes, and unverifiable vendor claims. It does not measure vulnerability detection or incident response.

Independent assurance framework

Gate 1: provenance and asset context; Gate 2: independently labelled vulnerabilities and benign controls; Gate 3: accuracy and false-negative testing across PHP versions, SAPIs and configurations; Gate 4: evidence-grounded remediation and rollback safety; Gate 5: repeatability, calibration and drift; Gate 6: approval, audit trail and incident review. For LLM judges, blind model identity and order, score against experts, and explicitly measure abstention.

Research design for a real pilot

Create 300+ independently adjudicated scenarios drawn from authorized lab builds, benign synthetic logs, vendor advisories and incident-response playbooks. Split development and holdout sets by scenario family; preregister thresholds. Compare (a) deterministic rules, (b) security analyst decisions, (c) LLM-assisted workflows, and (d) an OpenVals evaluation integration once actually implemented. Record precision, recall, FNR, FPR, Brier/calibration, time to verified answer, hallucinated fixes, and human escalation. RedShield testing should remain defensive and isolated.

Publication guardrails

Publish the synthetic numbers only with the label SYNTHETIC / RULE-BASED DEMONSTRATION. Never describe them as live PHP2Shell detection, OpenVals product accuracy, RedShield exploit testing, AI-model performance, or independent proof of enterprise readiness. The 240 cases are generated and not a random sample of real assets. The labels are circular relative to the verified-backport rule.

Actionable enterprise guidance

Patch PHP using vendor-supported packages, check backported package advisories and restart affected workers. Prioritize exposed services and review anomalous PHP worker failures and unusual request patterns. WAF controls are supplementary, not a replacement for the PHP security update. Do not treat an unverified backport claim as evidence of remediation.

Source register

S1 PHP official advisory https://www.php.net/archive/2026.php (21 Oct 2026). S2 Wiz research https://www.wiz.io/blog/php2shell-php-rce (21 Oct 2026). S3 Cloudflare https://blog.cloudflare.com/php-vulnerabilities-waf-protection (21 Oct 2026). S4 Red Hat https://access.redhat.com/security/vulnerabilities/RHSB-2026-013 (21 Oct 2026). S5 Plesk https://support.plesk.com/hc/en-us/articles/44397729587351-Vulnerability-CVE-2026-109618-and-CVE-2026-109619-PHP2Shell-Remote-code-execution-in-PHP-shipped-with-Plesk (22 Oct 2026).

Disclosure and authorship

OpenVals x RedShield | DrPinnacle Research Case Study 002 | 23 October 2026. Prepared as a reproducible research demonstration. Public-source claims are attributed; benchmark observations are from the included Python script. This report does not constitute an external security audit or product certification.